

Modelo de Encuesta Integral TIBER-EU / TIBER-ES

Evaluación de Indicadores, Métricas y Prácticas Organizativas

Versión 1.0 – Borrador para prueba piloto nacional

Destinatarios: CISOs, responsables de continuidad de negocio, riesgo operacional, TI, auditoría interna y alta dirección implicada en TIBER-EU / TIBER-ES.

0. Instrucciones generales

- Duración estimada de respuesta: 45–60 minutos (sí, lo sabemos; la ciberresiliencia no cabe en 5 minutos).
- La encuesta está diseñada para una entidad concreta; grupos deben responder por cada entidad principal sujeta a TIBER-ES o equivalente.

Utilice la siguiente escala cuando se le pida valorar el grado de implantación o madurez:

- - 0 – No existe / No se aplica / No sabemos de qué nos habla.
 - 1 – Existe de forma ad hoc, poco formalizada.
 - 2 – Existe, formalizada, pero con aplicación limitada o irregular.
 - 3 – Implantación generalizada con resultados aceptables.
 - 4 – Implantación avanzada, integrada en procesos de gestión.
 - 5 – Implantación excelente, monitorizada y en mejora continua.
- Cuando se indique “respuesta abierta”, sea todo lo sintético que pueda sin sacrificar la precisión; el objetivo no es escribir una novela, aunque la tentación sea grande.

Utilice la siguiente escala cuando se le pida valorar el grado de implantación o madurez:

- 0 – No existe / No se aplica / No sabemos de qué nos habla.
- 5 – Implantación excelente, monitorizada y en mejora continua.

Cuando se indique “respuesta abierta”, sea todo lo sintético que pueda sin sacrificar la precisión; el objetivo no es escribir una novela, aunque la tentación sea grande.

1. Identificación de la entidad (bloque contextual)

1.1. Tipo de entidad principal:

- ☐ Entidad de crédito.
- ☐ Entidad aseguradora/reaseguradora.
- ☐ Gestora de fondos/activos.
- ☐ Infraestructura de mercado financiero (CCP, CSD, sistema de pagos, etc.).
- ☐ Proveedor tecnológico crítico para el sector financiero.
- ☐ Otro (especificar brevemente): _____

1.2. Tamaño aproximado por activos totales o volumen gestionado:

- ☐ Muy grande (top 3 nacional en su categoría).
- ☐ Grande.
- ☐ Mediana.
- ☐ Pequeña, pero con alta criticidad funcional (lo que viene siendo “pequeña pero matona”).

1.3. ¿La entidad está sujeta formalmente a TIBER-ES o a otra implementación nacional TIBER-XX?

- ☐ Sí, TIBER-ES.
- ☐ Sí, otra TIBER-XX (indicar país): _____
- ☐ No, pero ha realizado pruebas alineadas con TIBER-EU de forma voluntaria.
- ☐ No, y tampoco hemos hecho nada equivalente (todavía).

1.4. Rol principal de la persona que responde:

- ☐ CISO / Responsable máximo de ciberseguridad.
- ☐ Responsable de continuidad de negocio / resiliencia operacional.
- ☐ Responsable de riesgo operacional / no financiero.
- ☐ Responsable de auditoría interna.
- ☐ Miembro de la alta dirección / Consejo.
- ☐ Otro (especificar): _____

2. Gobernanza, alcance y funciones críticas (CIFs)

2.1. ¿Dispone la entidad de un inventario formal de **funciones críticas o importantes (CIFs)** aprobado por el órgano de administración?

- ☐ Sí, formalmente aprobado y revisado al menos una vez al año.
- ☐ Sí, formalmente aprobado pero su revisión es más esporádica.
- ☐ Existe un inventario, pero no ha pasado por el órgano de administración.
- ☐ Tenemos algo parecido, pero no nos atrevemos a llamarlo “inventario formal”.
- ☐ No disponemos de inventario de CIFs.

2.2. Grado de madurez del proceso de identificación de CIFs (escala 0–5):

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

- ☐ 4

- ☐ 5

2.3. ¿En qué medida se basa la identificación de CIFs en análisis de impacto de negocio (BIA) estructurados?

- ☐ Totalmente (todas las CIFs se apoyan en BIA documentado).
- ☐ Mayoritariamente (la mayoría se apoyan en BIA, alguna CIF “histórica” sobrevive por tradición).
- ☐ Parcialmente (solo algunas áreas críticas tienen BIA).
- ☐ Apenas (las CIFs se definen por intuición, ruido mediático o tradición oral).
- ☐ No utilizamos BIA para las CIFs.

2.4. Cobertura de CIFs por pruebas TIBER-EU / TIBER-ES en los últimos tres años:

Indique, aproximadamente, qué porcentaje de sus CIFs han sido cubiertas al menos una vez por el alcance de una prueba TIBER:

- ☐ 0–20 %
- ☐ 21–40 %
- ☐ 41–60 %
- ☐ 61–80 %
- ☐ Más del 80 %
- ☐ No sabemos/No consta.

2.5. En las pruebas realizadas, ¿cómo se ha decidido el alcance de CIFs? (puede marcar varias):

- ☐ Basado en BIA formal.
- ☐ Basado en requerimientos del TCT / supervisor.
- ☐ Negociación entre CISO, negocio y proveedor de RT (“el triángulo de las Bermudas”).
- ☐ En función de la disponibilidad de entornos y personal.
- ☐ Otros criterios (especificar brevemente): _____

2.6. Grado de implicación del Consejo de Administración en la aprobación del alcance del test TIBER (escala 0–5):

0 significa “firma delegada sin debate”, 5 significa “debate informado y consciente de riesgos y beneficios”.

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3
- ☐ 4
- ☐ 5

2.7. Comentario abierto sobre retos principales para definir el alcance de CIFs (máx. 200 palabras):

3. Inteligencia de amenazas (GTL, TTIR)

3.1. ¿Se ha utilizado un informe de paisaje de amenazas genérico (GTL) para el sector financiero como entrada al TTIR de la entidad?

- ☐ Sí, elaborado por una autoridad nacional (p. ej. INCIBE, CCN, Banco de España, etc.).
- ☐ Sí, elaborado por un organismo internacional o el BCE.
- ☐ Sí, elaborado por un proveedor de inteligencia de amenazas comercial.
- ☐ No, el TTIR se elaboró sin referencia explícita a un GTL sectorial.
- ☐ No sabemos si se utilizó GTL; quizá alguien, en algún correo, lo mencionó.

3.2. Origen principal del **Targeted Threat Intelligence Report (TTIR)**:

- ☐ Proveedor externo seleccionado conforme a TIBER-EU.
- ☐ Capacidad interna de ciberinteligencia de la entidad.
- ☐ Combinación de capacidad interna y proveedor externo.
- ☐ No se elaboró un TTIR formal (aunque hubo “cierto análisis previo”).

3.3. Grado de alineamiento del TTIR con amenazas reales observadas en el sector financiero nacional en los últimos 12 meses (escala 0–5):

- ☐ 0 – No tenía mucho que ver con nuestra realidad.
- ☐ 1 – Coincidió parcialmente, más por casualidad que por diseño.
- ☐ 2 – Podría decirse que era razonable, si uno es optimista.
- ☐ 3 – Adecuado en líneas generales.
- ☐ 4 – Muy bien alineado, se reconocían actores y TTPs sin necesidad de mucha fe.
- ☐ 5 – Excelente, casi parecía un documental sobre nuestras propias pesadillas.

3.4. Cobertura de actores de amenaza en el TTIR:

- ☐ Delincuencia organizada.
- ☐ Grupos APT patrocinados por Estados.
- ☐ Insider malicioso.
- ☐ Insiders negligentes / errores humanos sistemáticos.
- ☐ Proveedores y terceros comprometidos.
- ☐ Otros (especificar): _____

3.5. ¿Se actualizó el TTIR durante la ejecución del test TIBER (en función de nueva información, hallazgos o incidentes paralelos)?

- ☐ Sí, con actualizaciones planificadas (p. ej. revisión mensual o por hitos).
- ☐ Sí, de forma reactiva, ante hallazgos relevantes.
- ☐ No, se mantuvo como documento estático.
- ☐ Desconocido.

3.6. Grado de integración del TTIR con otros procesos de la entidad (gestión de riesgos, SOC/SIEM, planificación de controles) – escala 0–5:

- ☐ 0 – Documento “de museo”: se guarda, pero nadie lo usa.
- ☐ 1 – Se consultó para la prueba y poco más.

- [] 2 – Sirvió para ajustar algunos casos de uso / reglas.
- [] 3 – Se integró de forma razonable en procesos de riesgo y SOC.
- [] 4 – Se ha incorporado al ciclo regular de ciberinteligencia y revisiones de controles.
- [] 5 – Es una referencia viva y central para la gestión de ciberamenazas.

4. Red Team (RTT), escenarios y banderas

4.1. ¿Se contrató un **Red Team externo** acreditado o con experiencia probada en marcos TIBER-EU/TLPT?

- [] Sí, proveedor con experiencia específica en TIBER-EU/TIBER-ES.
- [] Sí, proveedor con experiencia en red teaming avanzado pero no específicamente TIBER.
- [] Red Team interno de la entidad.
- [] Combinación de equipo interno y externo.
- [] No se utilizó un Red Team formal (no aplicable / aún no hemos realizado pruebas).

4.2. Número de escenarios previstos vs. ejecutados efectivamente durante la prueba más reciente:

- Escenarios previstos: _
- Escenarios ejecutados: _

4.3. Principales tipos de escenarios utilizados (marque todos los que apliquen):

- [] Compromiso de estaciones de trabajo de empleados.
- [] Compromiso de usuarios privilegiados / administradores.
- [] Explotación de aplicaciones expuestas a Internet.
- [] Compromiso de terceros/proveedores críticos.
- [] Abuso de canales de pago / liquidación.
- [] Ataques a sistemas de mercado / trading.
- [] Otros (especificar): _____

4.4. Porcentaje aproximado de **banderas u objetivos** alcanzados por el RTT sin ayuda del Control Team (leg-ups):

- [] 0–20 %
- [] 21–40 %
- [] 41–60 %
- [] 61–80 %
- [] Más del 80 %
- [] No aplicable / No consta.

4.5. Frecuencia de “leg-ups” durante los escenarios (ayuda directa del Control Team):

- [] Ninguna (el RTT se bastó y sobró).
- [] Pocas (1–2 ocasiones muy puntuales).
- [] Moderada (varias veces, pero justificadas por limitaciones operativas).
- [] Alta (sin leg-ups, habría habido más frustración que aprendizaje).

4.6. Grado de innovación de las TTPs utilizadas (escala 0–5):

- ☐ 0 – Nada nuevo; todo estaba en la última diapositiva de formación del SOC.
- ☐ 1 – Algún matiz distinto, pero nada que revolucionara la detección.
- ☐ 2 – Varias TTPs novedosas para la organización.
- ☐ 3 – Alta diversidad y novedad, con impacto claro en lecciones aprendidas.
- ☐ 4 – El SOC todavía está procesando algunas de ellas.
- ☐ 5 – Hubo que inventar vocabulario interno para describir ciertas cadenas de ataque.

5. Detección, respuesta y capacidades del Blue Team

5.1. ¿El Blue Team estaba **informado** de que se iba a realizar el test TIBER durante el período de ejecución?

- ☐ Sí, conocía la existencia del test (pero no los detalles).
- ☐ No, el test fue completamente ciego para el Blue Team.
- ☐ Parcialmente (solo algunos mandos conocían que “algo podría pasar”).
- ☐ No aplicable / No se ha realizado aún prueba TIBER.

5.2. Para la prueba más reciente, indique la **mediana de tiempo de detección (MTTD)** de actividades del RTT en escenarios críticos (elija la categoría más ajustada):

- ☐ Menos de 1 hora.
- ☐ Entre 1 y 24 horas.
- ☐ Entre 1 y 7 días.
- ☐ Más de 7 días.
- ☐ No se detectó durante la ejecución; solo a posteriori en el análisis.
- ☐ No consta / No medido.

5.3. **Mediana de tiempo de contención (MTTR)** desde la primera detección hasta la neutralización efectiva de la actividad del RTT (en escenarios críticos):

- ☐ Menos de 4 horas.
- ☐ Entre 4 y 24 horas.
- ☐ Entre 1 y 7 días.
- ☐ Más de 7 días.
- ☐ No se consiguió contener completamente en el período de prueba.
- ☐ No consta / No medido.

5.4. Porcentaje aproximado de actividades del RTT que fueron detectadas **en tiempo real** por el Blue Team (SOC, herramientas de monitorización, etc.):

- ☐ 0–20 %
- ☐ 21–40 %
- ☐ 41–60 %
- ☐ 61–80 %
- ☐ Más del 80 %
- ☐ No consta / No medido.

5.5. ¿Cuántas detecciones relevantes se debieron principalmente a **usuarios de negocio o personal no técnico**?

- ☐ Ninguna.
- ☐ Alguna, que aún se comenta en los pasillos.
- ☐ Varias, lo que nos hace pensar que la concienciación funciona mejor de lo que creíamos.
- ☐ La mayoría, lo que plantea cuestiones sobre la eficacia de la detección técnica.
- ☐ No consta / No medido.

5.6. Grado de integración entre el Blue Team y otras funciones (riesgo, continuidad, fraude, etc.) durante la gestión de los escenarios TIBER (escala 0–5):

- ☐ 0 – Cada uno en su silo, con sus excels y sus rezos.
- ☐ 1 – Coordinación puntual, más por personas concretas que por proceso.
- ☐ 2 – Se activaron mecanismos de coordinación existentes, con resultados desiguales.
- ☐ 3 – Coordinación razonablemente fluida.
- ☐ 4 – Integración sólida en el modelo de gestión de incidentes.
- ☐ 5 – Integración ejemplar, casi de libro de texto.

6. Purple teaming, remediación y aprendizaje

6.1. Tras la ejecución del test, ¿se realizaron ejercicios formales de **purple teaming** (repetición de escenarios con colaboración activa entre Red y Blue)?

- ☐ Sí, con varios escenarios clave.
- ☐ Sí, pero de forma muy limitada.
- ☐ No, aunque se hicieron sesiones de revisión “en mesa”.
- ☐ No se realizaron ejercicios de este tipo.

6.2. Si se realizaron ejercicios de purple teaming, ¿se observó una mejora en el MTDD en escenarios repetidos?

- ☐ Sí, mejora superior al 50 %.
- ☐ Sí, mejora entre el 25 % y el 50 %.
- ☐ Sí, mejora inferior al 25 %.
- ☐ No se observaron mejoras significativas.
- ☐ No se midió de forma cuantitativa.

6.3. ¿Qué porcentaje aproximado de recomendaciones **críticas** del informe del Red Team (RTTR) se implementaron en los 12 meses posteriores?

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–100 %
- ☐ No consta / No aplicable.

6.4. ¿Y de las recomendaciones **altas** en los 24 meses posteriores?

- ☐ 0–25 %

- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–100 %
- ☐ No consta / No aplicable.

6.5. ¿Existe un proceso formal para revisar lecciones aprendidas de TIBER-ES/TIBER-EU con el órgano de administración?

- ☐ Sí, con sesiones específicas y documentación dedicada.
- ☐ Sí, pero integrado de forma periférica en otros informes (riesgos, auditoría, etc.).
- ☐ Informalmente, según agenda y prioridades del momento.
- ☐ No existe un proceso específico.

6.6. Grado en que las lecciones aprendidas de TIBER han influido en la **planificación de inversiones** en ciberseguridad y resiliencia (escala 0–5):

- ☐ 0 – Ninguna influencia perceptible.
- ☐ 1 – Influencia marginal.
- ☐ 2 – Algunas inversiones se justificaron por hallazgos TIBER.
- ☐ 3 – Impacto notable en el portfolio de proyectos.
- ☐ 4 – Factor clave en la priorización de iniciativas.
- ☐ 5 – Verdadero motor de la estrategia de ciberresiliencia.

6.7. Pregunta abierta: describa el principal cambio positivo que no habría ocurrido sin un test TIBER-ES/EU (máx. 300 palabras).

7. Relación con supervisores, terceros y reconocimiento cruzado

7.1. ¿Ha participado la entidad en pruebas TIBER realizadas en **colaboración con otras entidades** (ejercicios multiparte)?

- ☐ Sí, a nivel nacional (varias entidades españolas).
- ☐ Sí, con entidades de otras jurisdicciones TIBER-XX.
- ☐ No, pero lo estamos valorando.
- ☐ No, y no lo consideramos prioritario.

7.2. ¿Se ha logrado que un test TIBER sea **reconocido por varias autoridades** o supervisores, evitando la duplicación de pruebas?

- ☐ Sí, reconocimiento formal por más de una autoridad.
- ☐ Reconocimiento informal (aceptación tácita en otros foros).
- ☐ No, cada jurisdicción ha requerido su propio ejercicio.
- ☐ No aplicable.

7.3. Nivel de coordinación con proveedores y terceros críticos durante la prueba:

- ☐ Participación activa en el diseño de escenarios y remediación.
- ☐ Participación limitada (información y autorización básica).

- ☐ Resistencia significativa o reticencias a participar.
- ☐ No se incluyó a terceros en los escenarios.

7.4. Comentario abierto sobre retos regulatorios, contractuales o de seguro relacionados con TIBER-ES/EU (máx. 300 palabras):

8. Indicadores internos, ROI y visión global

8.1. ¿Dispone la entidad de un **cuadro de mando** específico de métricas derivadas de TIBER (MTTD, MTTR, cobertura de CIFs, cumplimiento de plazos, etc.)?

- ☐ Sí, integrado en el cuadro de mando de ciberseguridad.
- ☐ Sí, pero como artefacto separado, que aparece y desaparece según el comité.
- ☐ No, se manejan métricas ad hoc para cada ejercicio.
- ☐ No se manejan métricas cuantitativas específicas.

8.2. En una escala de 0–5, valore hasta qué punto la entidad ha intentado estimar el **ROI** de las pruebas TIBER (en términos de reducción de riesgo, cumplimiento y aprendizaje organizativo):

- ☐ 0 – Nunca se ha planteado.
- ☐ 1 – Se ha mencionado en alguna presentación, sin números.
- ☐ 2 – Se han hecho estimaciones cualitativas.
- ☐ 3 – Se han hecho estimaciones semi-cuantitativas.
- ☐ 4 – Se han calculado indicadores internos de ROI.
- ☐ 5 – El ROI está formalmente cuantificado y monitorizado.

8.3. Visión global de la utilidad de TIBER-EU/TIBER-ES para su organización (escala 0–5):

- ☐ 0 – Un trámite caro.
- ☐ 1 – Interesante, pero poco alineado con nuestra realidad.
- ☐ 2 – Útil, con margen de mejora.
- ☐ 3 – Muy útil para identificar brechas y prioridades.
- ☐ 4 – Fundamental para nuestra estrategia de resiliencia.
- ☐ 5 – Transformador, ha cambiado la conversación interna sobre ciberseguridad.

8.4. Comentario final (máx. 300 palabras): si pudiera cambiar **un solo indicador** del marco TIBER o de su aplicación nacional para que reflejara mejor la realidad de su entidad, ¿cuál sería y por qué?

Fin del modelo de encuesta. Gracias por dedicarle tiempo; prometemos que los gráficos resultantes serán espectaculares.